

FREE RESOURCE · ENGLISH

30-point business IT self-assessment checklist

Use this checklist to identify gaps in infrastructure, security, data protection, and IT operations before planning an upgrade or major investment.

Mark [x] Yes, [?] Unknown, or [] No. Prioritize every Unknown or No item according to its impact on business operations.

1. Network and Wi-Fi

- ☐ 01. An up-to-date logical and physical network diagram is available.
- ☐ 02. All switches, access points, routers, and Internet links are recorded in an asset list.
- ☐ 03. Office, server, camera, production, and guest networks are separated according to business needs.
- ☐ 04. Wi-Fi coverage and capacity have been measured in important working areas.
- ☐ 05. Internet failover, network monitoring, and alert responsibilities are defined.

2. Firewall and access control

- ☐ 06. Firewall firmware, security subscriptions, and support status are current.
- ☐ 07. Inbound and outbound firewall rules are reviewed and have clear business owners.
- ☐ 08. Remote access uses VPN and multi-factor authentication where appropriate.
- ☐ 09. Administrative accounts are separated from daily user accounts and follow least privilege.
- ☐ 10. Security logs are retained, monitored, and reviewed on a defined schedule.

3. Accounts and Microsoft 365

- ☐ 11. Every employee uses an individual account; shared accounts are controlled and documented.
- ☐ 12. Multi-factor authentication is enabled for administrators and important accounts.
- ☐ 13. Account onboarding, role changes, and offboarding follow an approved process.
- ☐ 14. SharePoint, OneDrive, mailbox, and shared folder permissions are reviewed periodically.
- ☐ 15. Email anti-phishing controls and account recovery information are maintained.

4. Servers, storage, and backup

- ☐ 16. Server and NAS health, capacity, warranty, and support status are monitored.
- ☐ 17. Critical data follows the 3-2-1 backup principle or an equivalent documented strategy.
- ☐ 18. At least one recovery copy is isolated, offline, or protected from routine user access.
- ☐ 19. Restore tests are performed on a schedule and the results are documented.
- ☐ 20. Recovery time and acceptable data loss targets are agreed with business owners.

5. Operations and documentation

- ☐ 21. Hardware, software, licenses, owners, warranties, and renewal dates are tracked.
- ☐ 22. Network diagrams, configuration backups, credentials, and operating procedures are controlled.
- ☐ 23. Incident contacts, escalation levels, and communication responsibilities are documented.
- ☐ 24. Operating systems, servers, network devices, and endpoint software follow a patching schedule.
- ☐ 25. Major vendor quotations receive an independent technical and total-cost review.

6. Security readiness and planning

- ☐ 26. Endpoint protection covers all supported computers and servers.
- ☐ 27. External exposure, important vulnerabilities, and remediation priorities are reviewed.
- ☐ 28. An annual IT budget and improvement roadmap are aligned with business plans.
- ☐ 29. The company periodically practices response to Internet outage, data loss, or ransomware.
- ☐ 30. A named owner and review schedule exist for every high-priority IT risk.

Suggested review: 25–30 Yes = controlled foundation; 18–24 Yes = targeted improvements needed; below 18 Yes = prioritize a structured assessment.

This checklist supports an initial self-review and does not replace a formal technical or security assessment.

TÀI LIỆU MIỄN PHÍ · TIẾNG VIỆT

Checklist 30 điểm tự đánh giá hệ thống CNTT

Sử dụng checklist để nhận diện các khoảng trống về hạ tầng, an toàn thông tin, bảo vệ dữ liệu và vận hành trước khi lập kế hoạch nâng cấp hoặc đầu tư lớn.

Đánh dấu [x] Có, [?] Chưa rõ hoặc [] Chưa có. Ưu tiên xử lý các mục Chưa rõ và Chưa có theo mức độ ảnh hưởng đến hoạt động kinh doanh.

1. Mạng và Wi-Fi

- ☐ 01. Có sơ đồ mạng logic và vật lý được cập nhật theo hiện trạng.
- ☐ 02. Switch, điểm truy cập Wi-Fi, router và đường truyền Internet được ghi nhận trong danh mục tài sản.
- ☐ 03. Mạng văn phòng, máy chủ, camera, sản xuất và khách được phân tách theo nhu cầu vận hành.
- ☐ 04. Vùng phủ sóng và khả năng đáp ứng Wi-Fi đã được đo tại các khu vực làm việc quan trọng.
- ☐ 05. Có phương án dự phòng Internet, giám sát mạng và phân công người tiếp nhận cảnh báo.

2. Tường lửa và kiểm soát truy cập

- ☐ 06. Phiên bản phần mềm, gói bảo mật và trạng thái hỗ trợ của tường lửa còn hiệu lực.
- ☐ 07. Các chính sách kết nối vào và ra được rà soát, có mục đích và người chịu trách nhiệm rõ ràng.
- ☐ 08. Truy cập từ xa sử dụng VPN và xác thực đa yếu tố khi phù hợp.
- ☐ 09. Tài khoản quản trị được tách khỏi tài khoản sử dụng hằng ngày và áp dụng quyền tối thiểu.
- ☐ 10. Nhật ký bảo mật được lưu giữ, giám sát và rà soát theo lịch.

3. Tài khoản và Microsoft 365

- ☐ 11. Mỗi nhân viên có tài khoản riêng; tài khoản dùng chung được kiểm soát và ghi nhận.
- ☐ 12. Xác thực đa yếu tố được bật cho quản trị viên và các tài khoản quan trọng.
- ☐ 13. Quy trình cấp mới, thay đổi quyền và thu hồi tài khoản đã được phê duyệt.
- ☐ 14. Quyền SharePoint, OneDrive, hộp thư và thư mục dùng chung được rà soát định kỳ.
- ☐ 15. Các tính năng chống lừa đảo qua email và thông tin khôi phục tài khoản được duy trì.

4. Máy chủ, lưu trữ và sao lưu

- ☐ 16. Sức khỏe, dung lượng, bảo hành và trạng thái hỗ trợ của máy chủ, NAS được theo dõi.
- ☐ 17. Dữ liệu quan trọng tuân theo nguyên tắc sao lưu 3-2-1 hoặc phương án tương đương đã được lập thành tài liệu.
- ☐ 18. Có ít nhất một bản sao phục hồi được cách ly, ngoại tuyến hoặc bảo vệ khỏi quyền truy cập thông thường.
- ☐ 19. Việc kiểm tra khôi phục được thực hiện theo lịch và có lưu kết quả.
- ☐ 20. Thời gian phục hồi và mức mất dữ liệu chấp nhận được đã thống nhất với bộ phận nghiệp vụ.

5. Vận hành và tài liệu

- [] 21. Phần cứng, phần mềm, giấy phép, người phụ trách, bảo hành và ngày gia hạn được theo dõi.
- [] 22. Sơ đồ mạng, bản sao cấu hình, thông tin quản trị và quy trình vận hành được kiểm soát.
- [] 23. Danh sách liên hệ khi có sự cố, mức độ ưu tiên và trách nhiệm truyền thông đã được quy định.
- [] 24. Hệ điều hành, máy chủ, thiết bị mạng và phần mềm đầu cuối được cập nhật theo lịch.
- [] 25. Các báo giá lớn của nhà cung cấp được đánh giá độc lập về kỹ thuật và tổng chi phí.

6. Mức độ sẵn sàng và kế hoạch

- [] 26. Giải pháp bảo vệ thiết bị đầu cuối bao phủ toàn bộ máy tính và máy chủ còn được hỗ trợ.
- [] 27. Các điểm truy cập từ Internet, lỗ hổng quan trọng và mức ưu tiên xử lý được rà soát.
- [] 28. Ngân sách CNTT năm và lộ trình cải tiến được gắn với kế hoạch kinh doanh.
- [] 29. Doanh nghiệp định kỳ diễn tập tình huống mất Internet, mất dữ liệu hoặc mã độc tống tiền.
- [] 30. Mỗi rủi ro CNTT ưu tiên cao đều có người phụ trách và lịch rà soát.

Gợi ý đánh giá: 25–30 mục Có = nền tảng được kiểm soát; 18–24 mục Có = cần cải thiện có trọng tâm; dưới 18 mục Có = nên ưu tiên đánh giá hệ thống có cấu trúc.

Checklist hỗ trợ rà soát ban đầu và không thay thế một cuộc đánh giá kỹ thuật hoặc an toàn thông tin chính thức.

無料資料・日本語

企業 IT 自己評価 30 項目チェックリスト

大規模な更新や投資を計画する前に、インフラ、情報セキュリティ、データ保護、IT 運用の不足点を確認するためのチェックリストです。

[x] 対応済み、[?] 不明、[]

未対応を記入してください。不明・未対応の項目は、業務への影響度に応じて優先順位を付けます。

1. ネットワークと Wi-Fi

- [] 01. 現状に合った論理・物理ネットワーク構成図がある。
- [] 02. スイッチ、アクセスポイント、ルーター、インターネット回線を資産一覧で管理している。
- [] 03. オフィス、サーバー、カメラ、製造、ゲスト用ネットワークを業務要件に応じて分離している。
- [] 04. 重要な作業エリアで Wi-Fi の電波範囲と収容能力を測定している。
- [] 05. インターネット回線の冗長化、監視、アラート対応責任者を定めている。

2. ファイアウォールとアクセス制御

- [] 06. ファイアウォールのソフトウェア、セキュリティ契約、サポートが有効である。
- [] 07. 内向き・外向き通信ルールを定期的に確認し、目的と責任者が明確である。
- [] 08. リモートアクセスで必要に応じて VPN と多要素認証を使用している。
- [] 09. 管理者アカウントを日常利用アカウントから分離し、最小権限を適用している。
- [] 10. セキュリティログを保存・監視し、決められた周期で確認している。

3. アカウントと Microsoft 365

- [] 11. 従業員ごとに個別アカウントを使用し、共有アカウントを管理・記録している。
- [] 12. 管理者と重要アカウントで多要素認証を有効にしている。
- [] 13. 入社、権限変更、退職時のアカウント手順を承認・運用している。
- [] 14. SharePoint、OneDrive、メールボックス、共有フォルダの権限を定期的に確認している。
- [] 15. メールのフィッシング対策とアカウント復旧情報を維持している。

4. サーバー、ストレージ、バックアップ

- [] 16. サーバーと NAS の状態、容量、保証、サポート期限を監視している。
- [] 17. 重要データに 3-2-1 原則、または文書化された同等のバックアップ方針を適用している。
- [] 18. 少なくとも 1 つの復旧用コピーを隔離、オフライン化、または通常アクセスから保護している。
- [] 19. 復元テストを定期的に実施し、結果を記録している。
- [] 20. 復旧時間と許容可能なデータ損失量を業務責任者と合意している。

5. 運用と文書

- [] 21. 機器、ソフトウェア、ライセンス、担当者、保証、更新日を管理している。
- [] 22. ネットワーク構成図、設定バックアップ、管理情報、運用手順を管理している。
- [] 23. 障害時の連絡先、優先度、情報共有の責任を文書化している。
- [] 24. OS、サーバー、ネットワーク機器、端末ソフトウェアを計画的に更新している。
- [] 25. 高額なベンダー見積書について技術面と総費用を第三者が確認している。

6. セキュリティ準備と計画

- [] 26. サポート対象の全 PC・サーバーに端末保護を導入している。
- [] 27. 外部公開範囲、重要な脆弱性、対応優先度を確認している。
- [] 28. 年間 IT 予算と改善ロードマップを事業計画に合わせている。
- [] 29. インターネット停止、データ損失、ランサムウェアを想定した訓練を定期的に行っている。
- [] 30. 優先度の高い IT リスクごとに責任者と確認周期を定めている。

評価目安：対応済み 25～30 項目 = 基盤を管理できている、18～24 項目 = 重点改善が必要、18 項目未満 = 体系的な現状評価を優先。

本チェックリストは初期確認を支援するもので、正式な技術・情報セキュリティ評価に代わるものではありません。